

eVDP

Script de présentation complet

Procédure minutée, texte à dire à chaque étape, et réponses préparées aux questions probables du jury

Projet CYBER-DEF 2 -- FASO SHIELD -- ELITE IT 2026

Chaque étape et chaque réponse ont été testées en direct sur la plateforme avant d'être écrites ici.

Avant de commencer

Ouvrez à l'avance, dans des onglets séparés :

- Votre compte Chercheur (déjà créé)
- Le compte Coordinateur national (déjà créé)
- Le compte DSI (déjà créé)
- Un onglet en navigation privée, pour la partie signalement anonyme

Remarque : Ayez vos codes TOTP (double authentification) prêts pour Coordinateur et DSI -- ces deux rôles l'exigent obligatoirement, la plateforme bloque tout le reste tant qu'elle n'est pas activée.

Attention : Point à vérifier avant la présentation : le compte DSI est rattaché à UNE organisation précise (visible sur sa fiche « Mon profil »). Au moment de soumettre le signalement de la Phase 1, choisissez bien cette MÊME organisation dans le champ « Organisation affectée » -- c'est ce qui permet de réutiliser exactement le même dossier, du début (Phase 1) jusqu'à la démonstration du correctif de sécurité (Phase 3), sans avoir à jongler entre plusieurs dossiers différents.

Le principe : un seul dossier, suivi de bout en bout

Les Phases 1, 2 et 3 utilisent VOLONTAIREMENT le même dossier -- celui que vous créez en Phase 1 -- pour que le jury suive une histoire continue plutôt que des exemples déconnectés. La séquence complète des statuts à appliquer, dans l'ordre exact, est donnée ci-dessous à chaque phase.

Vue d'ensemble

Phase	Compte	Démontre
0. Introduction	—	Le problème que résout eVDP
1. Signalement avec compte	Chercheur	Parcours complet, suivi personnel, crédit
1bis. Signalement anonyme	Aucun (navigation privée)	Canal ouvert à tous, code de suivi sécurisé
2. Réception et triage	Coordinateur national	Kanban, workflow interne, qualification
3. Le correctif de sécurité	Coordinateur puis DSI	Visibilité organisation contrôlée par statut

4. Bug Bounty	Coordinateur (+ Analyste si dispo)	Barème, cycle récompense, séparation des pouvoirs
5. Conformité et audit	Coordinateur national	MFA, PGP, traçabilité

Phase 0 — Le problème (1 min, sans écran)

🗨️ **À dire :** « Un citoyen ou chercheur qui découvre une faille de sécurité sur un service public burkinabè n'a aujourd'hui aucun canal officiel pour la signaler — et risque même des poursuites judiciaires pour l'avoir testée. C'est le problème qu'eVDP résout. »

Phase 1 — Le signalement, avec compte (3 min -- Onglet Chercheur)

1. Menu « Signaler ».
2. Montrer le bandeau de politique de divulgation.

🗨️ **À dire :** « Ce n'est pas une charte interne — le texte cite la vraie loi burkinabè sur l'accès frauduleux à un système, et garantit qu'un chercheur de bonne foi ne sera pas poursuivi : c'est le Safe Harbor. »

3. Remplir le formulaire (titre, organisation, description -- 30 caractères minimum, montrer le compteur qui vire au vert).
4. Cocher « Je souhaite être crédité publiquement ».
5. Montrer la carte « Signalement chiffré » à côté du formulaire.

🗨️ **À dire :** « Pour un détail qui rendrait la faille immédiatement exploitable en cas de fuite — un payload d'exploitation complet, par exemple — le déclarant peut chiffrer cette partie avec la clé publique nationale, toujours proposée ici, quelle que soit l'organisation visée. Le système détecte même automatiquement un contenu chiffré déposé en pièce jointe, sans action supplémentaire de sa part. »

6. Envoyer.

🗨️ **À dire :** « Le dossier existe maintenant avec un identifiant, statut « Soumis » — et les échéances internes du CSIRT démarrent déjà, en arrière-plan, avant même qu'un humain n'ait rien fait. »

Phase 1bis — Le signalement anonyme (2 min -- Onglet navigation privée)

1. Sur /report/, sans être connecté.
2. Remplir le formulaire, cocher « Signaler de manière anonyme », laisser l'adresse de contact vide.
3. Envoyer.

🗨️ **À dire :** « Notez ce code, il ne sera plus jamais affiché. »

Montrer le code à l'écran.

🗨️ **À dire :** « C'est le seul moment où il existe en clair — le système ne conserve jamais le code lui-même, seulement son empreinte hachée, exactement comme un mot de passe. Une fuite de la base ne permettrait à personne de le rejouer. »

4. Menu « Suivre mon signalement », coller le code.

🗨️ **À dire :** « Statut simplifié, en lecture seule, sans messagerie — c'est le juste niveau d'accès pour quelqu'un qui n'a pas de compte. Ce code reste valable 180 jours. »

🗨️ **À dire :** « Voilà le contraste : avec un compte, suivi complet et messagerie ; sans compte, un accès minimal mais réel, sans jamais devoir révéler son identité. »

Phase 2 — Réception et triage (3 min -- Onglet Coordinateur -- même dossier que la Phase 1)

1. Menu « Kanban » -- montrer la vue d'ensemble par colonnes (le dossier est visible dans « Soumis »).
2. Ouvrir le dossier -- montrer la carte « Rapport » (description, preuve de concept).
3. Carte « Changer le statut » -> choisir « Reçu » -> Appliquer.
4. Recommencer : « Changer le statut » -> choisir « Accusé de réception » -> Appliquer.

🗨️ **À dire :** « Le déclarant reçoit un email automatique ici — le système envoie systématiquement une notification interne ET un email en parallèle, dès qu'une adresse est connue. »

5. Recommencer : « Changer le statut » -> choisir « En triage » -> Appliquer.
6. Recommencer : « Changer le statut » -> choisir « Validé » -> Appliquer.

Remarque : Séquence complète de cette phase : Soumis -> Reçu -> Accusé de réception -> En triage -> Validé -- quatre clics sur « Changer le statut », chacun suivi de « Appliquer ». Le dossier est maintenant prêt pour la Phase 3.

Phase 3 — Le correctif de sécurité (3 min -- Onglets Coordinateur + DSI -- VOTRE MOMENT FORT, même dossier)

1. Onglet DSI : Kanban -- montrer qu'il est vide, ou que ce dossier n'y figure pas.

🗨️ **À dire :** « L'organisation concernée ne voit RIEN de ce dossier tant que le CSIRT n'a pas formellement décidé de l'impliquer — même si le dossier existe déjà, est validé, et la concerne directement. »

2. Onglet Coordinateur, sur le même dossier : carte « Changer le statut » -> choisir « Organisation contactée » -> Appliquer. C'est LE seul clic de cette phase -- gardez-le pour le moment où vous parlez, l'effet est immédiat.
3. Onglet DSI : rafraîchir la page Kanban -- le dossier apparaît.

🗨️ **À dire :** « C'est un vrai correctif de sécurité identifié et appliqué pendant le développement — avant, une organisation voyait un signalement dès sa création, même non trié, ce qui contredisait la raison d'être même d'un CSIRT coordinateur. »

Phase 4 — Bug Bounty (3 min, si le temps le permet)

1. Menu « Programmes » -> ouvrir « Bug Bounty National - Services Publics » -> montrer le barème par sévérité.
2. Menu « Récompenses » -> ouvrir un dossier « Approuvée ».
3. Remplir « Enregistrer un versement » -> Enregistrer.

🗨️ **À dire :** « Le statut passe à « Payée » — mais aucun argent réel ne circule via eVDP, c'est une trace comptable uniquement, le virement se fait par les canaux financiers habituels de l'État. »

Remarque : Si vous avez un compte Analyste disponible : montrer qu'il peut proposer une récompense mais jamais l'approuver lui-même -- le principe des quatre yeux appliqué techniquement, pas juste déclaré.

Phase 5 — Conformité et clôture *(2 min -- Onglet Coordinateur)*

1. Rappeler la double authentification obligatoire pour tout rôle à privilège (déjà vécue en se connectant).

 **À dire :** « *Le pipeline email fonctionne de bout en bout avec un vrai fournisseur -- ce n'est pas une maquette. Chaque notification suit le même mécanisme systématique : une entrée interne, et un email en parallèle dès qu'une adresse est connue -- jamais l'un sans l'autre, jamais une exception cachée. »*

2. Menu « Journal d'audit ».

 **À dire :** « *Chaque action sensible est journalisée, chaque rôle a des capacités précisément définies, et le système applique des contrôles de sécurité réels, pas seulement déclarés — c'est ce qu'on vient de vous démontrer en direct, pas juste affirmer. »*

Remarque : Minutage total : 14 à 17 minutes. Compressible en retirant la Phase 4 si le temps manque.

Questions anticipées du jury

Les réponses ci-dessous ont toutes été vérifiées précisément dans le code source avant d'être écrites -- ce ne sont pas des suppositions.

Sur le code de suivi anonyme

? Question possible : Pourquoi ne pas stocker le code, pourquoi seulement son empreinte ?

Vous répondez : « C'est le même principe que pour un mot de passe : on ne stocke jamais le secret lui-même, seulement une empreinte à sens unique. Si un jour la base de données était compromise, un attaquant qui la lit ne pourrait reconstituer aucun code utilisable, ni usurper le suivi d'un signalement anonyme d'autrui. »

Si on insiste : « C'est un vrai compromis assumé, pas un oubli. Si le code est perdu, personne — pas même l'équipe eVDP — ne peut le récupérer, puisqu'il n'est jamais stocké en clair. Mais ce n'est pas grave pour la sécurité globale : le signalement continue d'être traité normalement par le CSIRT. Ce qui est perdu, c'est uniquement la capacité du déclarant à vérifier lui-même l'avancement. On accepte cet inconvénient ponctuel plutôt que de créer une faiblesse structurelle — un code récupérable serait un code volable. »

? Question possible : Pourquoi seulement un statut simplifié, sans messagerie, pour l'anonyme ?

Vous répondez : « Parce que ce code est un simple jeton, détenu par n'importe qui qui le possède physiquement — il n'y a aucune identité vérifiée derrière. Si quelqu'un d'autre que le déclarant original tombait sur ce code, il ne pourrait voir qu'un statut général, jamais le détail technique de la faille ni les échanges internes. La messagerie, elle, suppose une conversation dans la durée avec quelqu'un d'identifiable — un jeton anonyme ne garantit pas que c'est toujours la même personne de l'autre côté. »

? Question possible : Pourquoi 180 jours, pas plus, pas moins ?

Vous répondez : « Ce délai est calé sur le cycle de vie réel d'un dossier : 72 heures pour l'accusé de réception, 5 jours ouverts pour le premier triage, jusqu'à 90 jours avant divulgation coordonnée. 180 jours laisse une vraie marge pour couvrir tout ce parcours, y compris un éventuel retard. On ne le rend pas permanent non plus : un identifiant qui ne périmait jamais, même haché, reste une trace qui traîne indéfiniment en base — de la bonne hygiène de sécurité, tout simplement. »

? Question possible : Pourquoi ce code et pas simplement le numéro de dossier ?

Vous répondez : « Le numéro de dossier est volontairement prévisible — c'est un numéro de référence public, comme un numéro de commande, généré par un simple compteur séquentiel : EVDP-2026-000001, puis 000002, puis 000003. Si on l'utilisait comme identifiant de suivi, n'importe qui pourrait consulter le statut de n'importe quel dossier simplement en essayant les numéros les uns après les autres. C'est exactement la même famille de faille qu'un IDOR — d'ailleurs un de nos propres dossiers de démonstration illustre précisément ce type de vulnérabilité. On ne pouvait pas construire le mécanisme de suivi anonyme sur cette même faiblesse qu'on démontre par ailleurs comme un problème de sécurité. »

? Question possible : D'où vient concrètement ce code ?

Vous répondez : « Il est généré par le module cryptographique standard de Python, `secrets.token_urlsafe(32)` — 256 bits de hasard pur, totalement indépendant du numéro de dossier. Le nombre de combinaisons possibles est si grand qu'il est impossible à deviner par tâtonnement. Et si quelqu'un essaie un code au hasard, le système répond exactement la même chose pour un code qui n'a jamais existé que pour un code expiré — jamais de message différent qui laisserait deviner qu'un code proche a existé un jour. »

Sur le correctif de sécurité (visibilité de l'organisation)

? Question possible : Pourquoi l'organisation ne voit-elle pas le dossier dès sa création ?

Vous répondez : « Parce que c'est exactement le problème que le cahier des charges identifie : un déclarant qui n'a aucun canal officiel risque des poursuites de la part de l'organisation visée. Si celle-ci voyait un signalement encore non vérifié, potentiellement faux, dès sa création, on recréerait ce même risque à l'intérieur même de la plateforme censée en protéger. L'accès ne s'ouvre qu'à partir du moment où le CSIRT, une autorité indépendante, a validé la faille et décidé formellement d'engager l'organisation. »

Sur le Bug Bounty

? Question possible : Pourquoi une personne ne peut-elle pas approuver sa propre proposition de récompense ?

Vous répondez : « C'est le principe des quatre yeux, standard sur les plateformes professionnelles comme HackerOne ou Bugcrowd : quand de l'argent public est en jeu, aucune personne seule ne doit pouvoir à la fois proposer et valider une dépense. Le code bloque explicitement cette situation, indépendamment du rôle — ce n'est pas qu'une question de capacité, l'auteur de la proposition est vérifié nommément et rejeté s'il tente d'approuver son propre dossier. »

? Question possible : Pourquoi un compte est-il obligatoire pour signaler sur un programme Bug Bounty, alors que le VDP accepte l'anonymat ?

Vous répondez : « Parce qu'une récompense doit pouvoir être versée à quelqu'un d'identifiable, avec un historique et une protection anti-fraude — un email jetable ou l'anonymat total ne permettent ni l'un ni l'autre. Le compte doit aussi avoir l'email vérifié et la double authentification activée avant de soumettre : un compte éligible à une récompense devient une cible de prise de contrôle, il doit être mieux protégé. Ce sont exactement les mêmes exigences que HackerOne, Bugcrowd, Intigriti ou YesWeHack. »

Sur l'infrastructure email

? Question possible : Pourquoi Gmail et pas un domaine gouvernemental ?

Vous répondez : « C'est un choix pragmatique de phase de démonstration, assumé comme tel. Une mise en production réelle utiliserait un domaine institutionnel — @anssi.bf ou @csirt.bf — avec les protections standard anti-usurpation (SPF, DKIM, DMARC), pour que les emails soient reconnus comme légitimes par les autres serveurs et ne finissent pas en spam, et pour porter une image officielle plutôt qu'une adresse Gmail générique. Le code n'a d'ailleurs rien à changer pour ça — le serveur SMTP est un simple paramètre de configuration, pas une dépendance codée en dur. »

? Question possible : Où se trouve ce serveur d'email ?

Vous répondez : « Deux serveurs différents, à ne pas confondre. eVDP héberge son propre serveur applicatif — la plateforme elle-même, sur notre VM, sous notre contrôle. Mais l'envoi d'email est délégué à un relais SMTP externe, ici Gmail pour la démonstration — un serveur de Google, hors de notre infrastructure, auquel on se connecte simplement comme le ferait n'importe quel client de messagerie. Peu de plateformes hébergent leur propre serveur mail de bout en bout ; la plupart s'appuient sur un service spécialisé pour garantir la délivrabilité. »

? Question possible : Le mot de passe du compte Gmail est-il exposé quelque part ?

Vous répondez : « Non — le mot de passe utilisé n'est pas le mot de passe principal du compte, mais un mot de passe d'application dédié : un mécanisme Google qui donne un accès limité, uniquement à l'envoi de mails via ce protocole, révoquant indépendamment sans toucher au compte principal ni à sa propre double authentification. Même l'envoi d'email suit un principe de moindre privilège. »

Sur la publication d'un advisory

? Question possible : Le statut du dossier et la publication de l'advisory sont-ils la même chose ?

Vous répondez : « Non, et c'est une nuance volontaire. Changer le statut d'un dossier vers « Publié » ne fait qu'annuler les échéances internes encore en attente — ça ne rédige ni ne publie rien de public. La publication réelle passe par un objet séparé, l'Advisory, avec son propre cycle : rédaction par un analyste,

puis publication qui exige une capacité différente, réservée au Coordinateur national. Un contrôle à deux personnes, comme pour les récompenses. »

En cas de blocage pendant la présentation

- Dossier invisible pour un compte qui devrait le voir -> vérifier le statut exact du dossier (le Kanban ne montre l'organisation qu'à partir de « Organisation contactée »).
- Compte bloqué à la connexion, demande un code à 6 chiffres -> double authentification obligatoire pour Coordinateur et DSI, ayez le générateur de code prêt.
- Transition de statut refusée -> le workflow interdit certains sauts directs ; repasser par les étapes intermédiaires, dans l'ordre.
- Si une réponse précise manque en session de questions -> ne pas improviser : « C'est un point que je peux vérifier précisément dans le code après la présentation » reste plus crédible qu'une réponse inventée.